

Healthcare Workforce Platform

Phase 1 + Phase 2 Developer Architecture Blueprint

IMPLEMENTATION BOUNDARY Android-first healthcare duty marketplace followed by the trusted workforce expansion. Phase 3 and later product capabilities are intentionally excluded from this build specification.

Prepared for: K. Dasarathan

Prepared by: Geerthan S

Version: 1.0 | Status: Developer handoff baseline | Date: 21 August 2026

No pricing, quotation, fee schedule, or commercial payment commitment is contained in this document.

DOCUMENT CONTROL

Governance, Scope and Authority

This specification is the implementation contract for the first two releases. Product behavior, data ownership, security controls and acceptance evidence take precedence over informal chat instructions.

Control	Decision	Owner
In scope	Phase 1 Healthcare Duty Marketplace MVP; Phase 2 Trusted Healthcare Workforce Network	Founder + product owner
Excluded	Permanent recruitment engine, AI intelligence, equipment commerce, advertising marketplace and later ecosystem modules	Change control
Commercial content	No prices, quotation values, subscription amounts or development fees	Explicitly excluded
Technical baseline	Flutter Android; Supabase Auth/PostgreSQL/Storage/Functions; browser admin; FCM	Architecture owner
Change rule	Any scope change requires written acceptance criteria, migration impact and release reassessment	Product + engineering

AUTHORITY Where a screen description conflicts with a state machine or security rule, the state machine and security rule win.

DOCUMENT CONTROL

How the Developer Must Use This Blueprint

Build vertically by user outcome, not as disconnected screens. Every workflow must be implemented through UI, API, database policy, audit record, telemetry and test evidence.

Required reading order

- Scope and architecture decisions
- Phase 1 workflows and screen contracts
- Phase 2 trust workflows
- Data model and RLS
- API, security, testing and release gates

Definition of implemented

- UI state exists for loading, empty, success, validation and recoverable error.
- Server enforces the rule independently of the client.
- RLS test proves unauthorized rows cannot be read or changed.
- Audit and analytics events are emitted without sensitive payloads.
- Automated tests and acceptance evidence are attached to the work item.

NON-NEGOTIABLE Do not embed privileged service keys in Flutter, trust client-supplied role values, expose verification documents publicly, or bypass lifecycle transitions with direct row updates.

NAVIGATION

Table of Contents

The document is organized as a build sequence. Each chapter ends in testable implementation contracts.

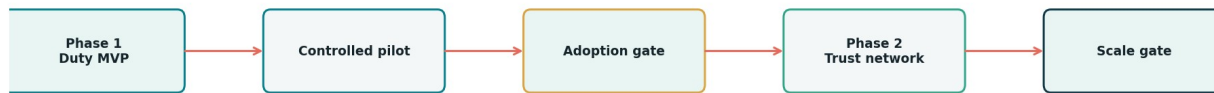
Chapter	Content
1	Product boundary, release gates, roles, quality attributes and architecture decisions
2	Phase 1 doctor, hospital and admin product specification
3	Phase 1 lifecycle rules, verification, notifications and operational controls
4	Phase 2 trusted network: availability, reliability, replacement, wallet and disputes
5	Database architecture, entities, indexes, migrations and RLS
6	API contracts, errors, concurrency, files and eventing
7	Security architecture, tools, privacy, audit, backups and incident response
8	Engineering structure, CI/CD, testing, Play Store rollout and handover

1. FOUNDATION

Product Objective and Delivery Boundary

Replace unstructured WhatsApp and Telegram duty coordination with a permissioned, searchable and auditable workflow for doctors, hospitals/clinics and platform administrators.

TWO-PHASE IMPLEMENTATION BOUNDARY



Phase outcome

- Phase 1 proves verified supply, duty posting, application, selection and completion in a controlled pilot.
- Phase 2 is released only after Phase 1 adoption and operational quality thresholds are met; it adds trust and recovery workflows.
- No patient clinical record, diagnosis, prescription or telemedicine consultation is stored.

NORTH-STAR BEHAVIOR A genuine duty can move from verified hospital need to verified doctor completion without manual group-message coordination.

1. FOUNDATION

Architecture Principles

These decisions protect extension capability without prematurely building Phase 3-5 features.

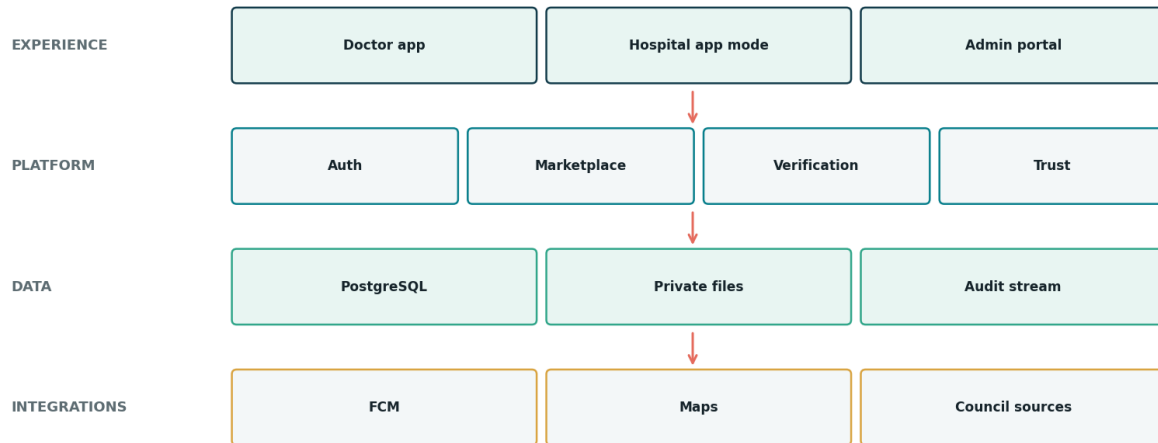
Principle	Implementation consequence
Server authority	Lifecycle transitions, permissions, entitlements and verification decisions execute server-side.
Deny by default	All exposed PostgreSQL tables use RLS; private storage uses policy-controlled signed access.
State machines	Duty, application, verification, replacement and dispute statuses use explicit allowed transitions.
Versioned contracts	Public API namespace begins at /v1; breaking changes require a new version.
Event-ready	Transactional outbox separates committed domain events from notification delivery.
Migration-safe	Additive schema migrations, feature flags and app minimum-version rules support staged releases.
Privacy minimization	Collect professional workforce data only; never repurpose community member data without consent.

1. FOUNDATION

System Context

The first implementation is a modular monolith on managed services. Domain boundaries are explicit so services can be separated later without rewriting the client contract.

PHASE 1 AND PHASE 2 ECOSYSTEM



Ownership boundaries

- Flutter owns presentation and local session state, not authorization decisions.
- PostgreSQL owns canonical state; Functions/RPC own complex transitions.
- Storage owns encrypted-at-rest documents; database stores metadata, hash and object key only.
- Admin operations are privileged, MFA-protected and audit logged.

1. FOUNDATION

User Roles and Tenancy Model

A user has one identity and one or more role memberships. Hospital access is organization-scoped so staff can be added later without shared credentials.

Actor	Tenant scope	Primary abilities	Hard restriction
Doctor	Own professional profile	Discover, apply, confirm, complete, feedback	Cannot view other applicants or private hospital records
Hospital staff	Assigned organization/facilities	Post, shortlist, select, confirm, close	Cannot access another organization
Verifier	Verification queue	Review evidence and record source checks	Cannot change duty assignments
Support admin	Cases and moderation	Handle reports and non-sensitive support	No unrestricted document download
Super admin	Platform	Break-glass administration	MFA, reason code and immutable audit required

1. FOUNDATION

Non-functional Quality Targets

Targets are pilot baselines and must be measured in staging and production rather than assumed.

Attribute	Target / rule	Evidence
Availability	Managed-service baseline; graceful read-only degradation for non-critical views	Synthetic checks + incident log
Performance	P95 API reads under 800 ms; writes under 1.2 s under agreed pilot load	k6 report
Mobile startup	Warm start under 2 s on supported mid-range Android test device	Device test log
Security	Zero critical/high unresolved findings at production gate	SAST/DAST/MobSF results
Recovery	Daily restore evidence; recovery objectives documented after staging drill	Restore runbook
Accessibility	Labels, focus order, contrast and scalable text on core flows	Manual + automated checklist
Observability	Every failed transition traceable by correlation ID without PII in logs	Log query evidence

1. FOUNDATION

Phase Gates and Rollout Decision

Phase 2 is not a calendar-only release. The product owner must confirm that Phase 1 has stable demand, verified users and controllable operations.

Gate	Minimum evidence	Decision
Pilot readiness	Verified test organizations and doctors; production security checklist; support owner	Open controlled cohort
Marketplace validity	Repeated genuine duties, qualified applications and completed assignments	Continue acquisition
Operational stability	Acceptable crash-free sessions, transition error rate and support backlog	Expand cohort
Trust need	Observed cancellations, availability friction and feedback demand	Enable Phase 2 modules
Phase 2 readiness	Migration rehearsed; replacement/dispute runbooks; reliability explainability tested	Staged Play release

RELEASE AUTHORITY The product owner signs the gate; engineering supplies evidence and a rollback plan.

2. PHASE 1

Phase 1 Capability Map

The MVP must complete the end-to-end duty loop before secondary convenience features are added.

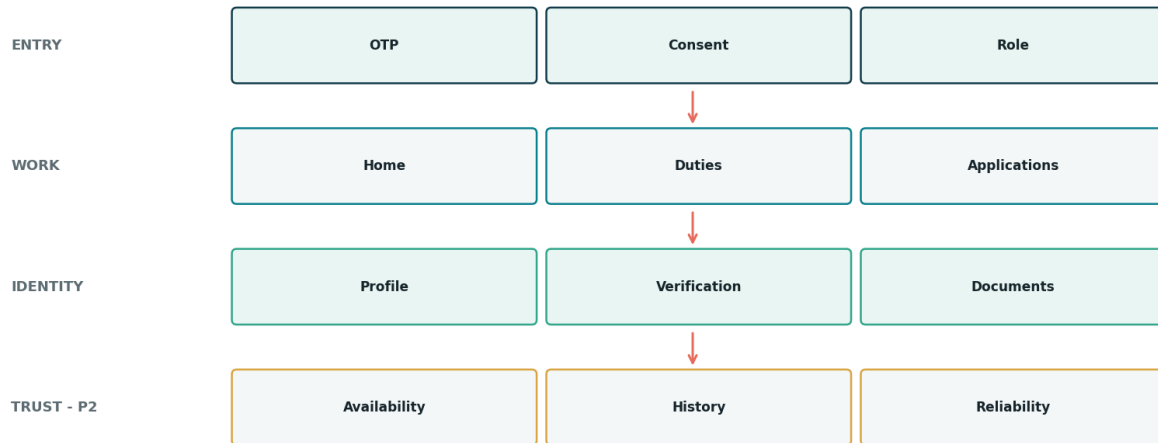
Domain	Must deliver	Not in Phase 1
Identity	OTP sign-in, consent, role membership, session controls	Social graph or public contact directory
Doctor	Profile, credential evidence, discovery, apply, application status	AI matching and premium ranking
Hospital	Organization verification, duty post, applicant review, selection	Recruitment ATS and bulk permanent hiring
Admin	Verification, moderation, configuration, audit visibility	General-purpose CRM
Trust	Verified badges and structured completion feedback	Public popularity leaderboard
Payments	Duty payment terms and acknowledgment fields	Escrow, split settlement or platform-held funds

2. PHASE 1

Doctor Application Sitemap

One Flutter application can expose role-specific navigation. The doctor path is optimized for urgent discovery and low-friction application.

DOCTOR APPLICATION SITEMAP



Bottom navigation

- Home: nearby/relevant duties and status cards
- Duties: search, filters, saved filter state
- Applications: submitted, shortlisted, selected, closed
- Profile: identity, verification, settings and support

2.3 PHASE 1 DOCTOR

Authentication and Consent

Implementation contract for the authentication and consent experience.

Contract	Specification
Primary user	Doctor / hospital staff
Fields / display	Phone, OTP, privacy notice version, role
Actions	Request OTP; verify; accept notice; select role
Backend data	users, sessions, consent_records, role_memberships
Rules and failure behavior	Rate-limited OTP; generic errors; revoke prior refresh token on risk
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.4 PHASE 1 DOCTOR

Doctor Onboarding

Implementation contract for the doctor onboarding experience.

Contract	Specification
Primary user	Doctor
Fields / display	Name, council, registration number, qualification, specialty, experience, city
Actions	Save draft; continue; submit profile
Backend data	doctors, doctor_qualifications, doctor_specialties
Rules and failure behavior	Draft survives interruption; canonical normalized registration identifier
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.5 PHASE 1 DOCTOR

Doctor Home Dashboard

Implementation contract for the doctor home dashboard experience.

Contract	Specification
Primary user	Doctor
Fields / display	Verification state, recommended/nearby duties, application status, alerts
Actions	Open duty; resume verification; view application
Backend data	duties, applications, verification_cases, notification_preferences
Rules and failure behavior	No unverified claim shown as verified; empty state explains next action
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.6 PHASE 1 DOCTOR

Duty Marketplace

Implementation contract for the duty marketplace experience.

Contract	Specification
Primary user	Doctor
Fields / display	Specialty, date, shift, location, distance, payment terms, facility badge
Actions	Search; filter; sort; paginate; open details
Backend data	duties, facilities, organizations, specialties
Rules and failure behavior	Server-side filters; cursor pagination; withdrawn duties disappear safely
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.7 PHASE 1 DOCTOR

Duty Details

Implementation contract for the duty details experience.

Contract	Specification
Primary user	Doctor
Fields / display	Facility, department, requirements, schedule, location, terms, status
Actions	Apply; withdraw; navigate; report
Backend data	duties, duty_versions, applications, moderation_reports
Rules and failure behavior	Apply button derives from eligibility and status, never client-only
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.8 PHASE 1 DOCTOR

Application Submission

Implementation contract for the application submission experience.

Contract	Specification
Primary user	Doctor
Fields / display	Profile snapshot, note, availability confirmation, terms acknowledgement
Actions	Submit once; cancel before selection
Backend data	applications, application_snapshots, audit_logs
Rules and failure behavior	Idempotency key prevents duplicate application; immutable snapshot supports review
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.9 PHASE 1 DOCTOR

My Applications

Implementation contract for the my applications experience.

Contract	Specification
Primary user	Doctor
Fields / display	Duty summary, hospital, submitted time, status, next action
Actions	Filter; open; withdraw; confirm selection
Backend data	applications, duties, assignments
Rules and failure behavior	Status labels map exactly to server enum; refresh on push receipt
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.10 PHASE 1 DOCTOR

Doctor Profile

Implementation contract for the doctor profile experience.

Contract	Specification
Primary user	Doctor
Fields / display	Identity, qualification, specialty, experience, locations, bio
Actions	Edit allowed fields; submit material changes
Backend data	doctors, qualifications, specialties, profile_versions
Rules and failure behavior	Verified fields become review-required when materially changed
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.11 PHASE 1 DOCTOR

Verification Center

Implementation contract for the verification center experience.

Contract	Specification
Primary user	Doctor
Fields / display	Case status, council ID, evidence checklist, reviewer request
Actions	Upload; replace draft; submit; respond; appeal
Backend data	verification_cases, verification_checks, verification_documents
Rules and failure behavior	Private signed upload; malware scan; decision reason shown safely
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.12 PHASE 1 DOCTOR

Notifications and Settings

Implementation contract for the notifications and settings experience.

Contract	Specification
Primary user	Doctor
Fields / display	Alert types, quiet hours, device status, privacy controls
Actions	Toggle preferences; revoke device; sign out; request account action
Backend data	device_tokens, notification_preferences, sessions
Rules and failure behavior	Transactional duty alerts cannot be disabled when an active assignment requires action
Acceptance evidence	UI state tests + API authorization test + RLS denial test + analytics event assertion

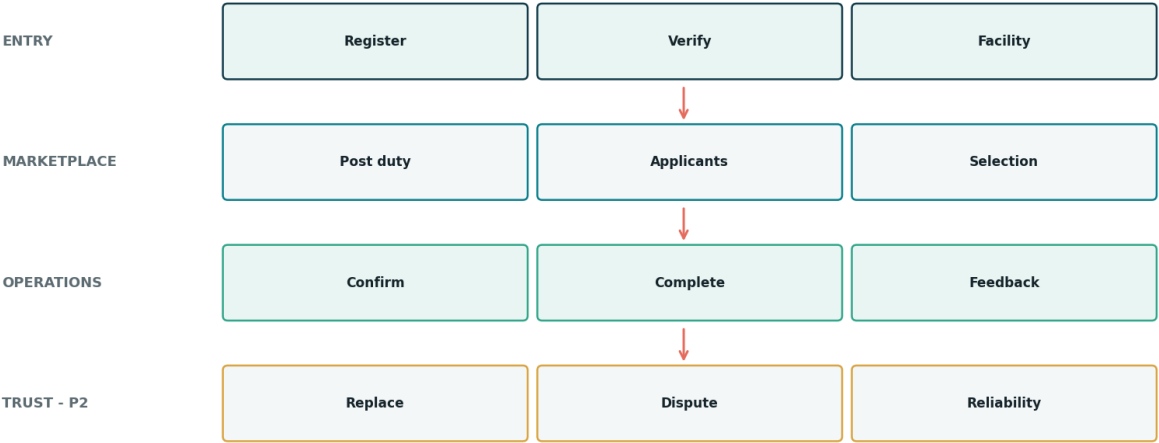
FUTURE-SAFE FOUNDATION Use stable IDs, typed DTOs, remote feature flags and additive fields so later modules can extend this screen without changing Phase 1 semantics.

2.13 PHASE 1 HOSPITAL

Hospital Workflow Sitemap

Hospital staff operate inside an organization membership and an assigned facility context. Never use a shared hospital login.

HOSPITAL WORKFLOW SITEMAP



2.14 PHASE 1 HOSPITAL

Organization Registration

Hospital-side contract for organization registration.

Contract	Specification
Fields / display	Legal/display name, organization type, address, contact, authorized representative
Actions	Create organization draft; add facility; submit verification
Data	organizations, facilities, organization_members
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.15 PHASE 1 HOSPITAL

Hospital Verification

Hospital-side contract for hospital verification.

Contract	Specification
Fields / display	Registration/licence details, establishment evidence, contact proof, reviewer requests
Actions	Upload evidence; submit; respond; view decision
Data	organization_verification_cases, verification_documents
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.16 PHASE 1 HOSPITAL

Hospital Dashboard

Hospital-side contract for hospital dashboard.

Contract	Specification
Fields / display	Open duties, new applications, action-required assignments, verification status
Actions	Create duty; review applicants; confirm completion
Data	duties, applications, assignments, organizations
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.17 PHASE 1 HOSPITAL

Create Duty Requirement

Hospital-side contract for create duty requirement.

Contract	Specification
Fields / display	Facility, specialty, qualification, date, start/end, department, headcount, terms, notes
Actions	Save draft; validate; preview; publish
Data	duties, duty_versions, specialties, facilities
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.18 PHASE 1 HOSPITAL

Duty Management

Hospital-side contract for duty management.

Contract	Specification
Fields / display	Published/draft/closed duties, application count, assignment state
Actions	Edit allowed fields; pause; close; duplicate
Data	duties, duty_versions, applications
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.19 PHASE 1 HOSPITAL

Applicant Review

Hospital-side contract for applicant review.

Contract	Specification
Fields / display	Verified profile snapshot, qualification match, experience, application note
Actions	Shortlist; reject with category; select
Data	applications, application_snapshots, doctors, verification_cases
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.20 PHASE 1 HOSPITAL

Selection and Confirmation

Hospital-side contract for selection and confirmation.

Contract	Specification
Fields / display	Selected doctor, expiry timer, duty terms snapshot, contact release rule
Actions	Offer; cancel before acceptance; confirm handoff
Data	assignments, assignment_events, contact_grants
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.21 PHASE 1 HOSPITAL

Completion and Feedback

Hospital-side contract for completion and feedback.

Contract	Specification
Fields / display	Attendance acknowledgment, completion time, payment acknowledgment, structured feedback
Actions	Mark completed; raise issue; submit feedback
Data	assignments, completion_records, payment_acknowledgements, feedback
Authorization	Active organization membership + facility permission; RLS restricts rows to organization_id
Validation	Server validates verification state, time ranges, enumerations, transition and expected record version
Acceptance	Happy path, stale-write conflict, cross-tenant denial, empty/error state and audit event pass

2.22 PHASE 1 ADMIN

Admin Dashboard

Privileged operations for admin dashboard.

Area	Implementation contract
Display	Queue counts, duty health, reports, delivery failures, security alerts
Actions	Read-only operational overview; drill into permissioned module
Access	Named admin identity, MFA, least-privilege permission and short privileged session
Mutation	Reason code mandatory; before/after summary and correlation ID written to append-only audit log
Sensitive files	On-demand signed URL, watermark/download event where practical; no permanent public link
Acceptance	Permission matrix tests prove verifier/support/super-admin separation

2.23 PHASE 1 ADMIN

Doctor Verification Queue

Privileged operations for doctor verification queue.

Area	Implementation contract
Display	Case age, risk markers, evidence completeness, source-check status
Actions	Claim case; request evidence; approve/reject; schedule recheck
Access	Named admin identity, MFA, least-privilege permission and short privileged session
Mutation	Reason code mandatory; before/after summary and correlation ID written to append-only audit log
Sensitive files	On-demand signed URL, watermark/download event where practical; no permanent public link
Acceptance	Permission matrix tests prove verifier/support/super-admin separation

2.24 PHASE 1 ADMIN

Hospital Verification Queue

Privileged operations for hospital verification queue.

Area	Implementation contract
Display	Organization evidence, facilities, authorized contact and duplicates
Actions	Review; request; approve; suspend with reason
Access	Named admin identity, MFA, least-privilege permission and short privileged session
Mutation	Reason code mandatory; before/after summary and correlation ID written to append-only audit log
Sensitive files	On-demand signed URL, watermark/download event where practical; no permanent public link
Acceptance	Permission matrix tests prove verifier/support/super-admin separation

2.25 PHASE 1 ADMIN

Duty and User Moderation

Privileged operations for duty and user moderation.

Area	Implementation contract
Display	Reported duties/users, history, linked assignments and evidence
Actions	Hide duty; warn; suspend; restore; escalate
Access	Named admin identity, MFA, least-privilege permission and short privileged session
Mutation	Reason code mandatory; before/after summary and correlation ID written to append-only audit log
Sensitive files	On-demand signed URL, watermark/download event where practical; no permanent public link
Acceptance	Permission matrix tests prove verifier/support/super-admin separation

2.26 PHASE 1 ADMIN

Configuration and Content

Privileged operations for configuration and content.

Area	Implementation contract
Display	Specialties, cities, duty categories, notice versions, minimum app version
Actions	Publish versioned configuration through validation
Access	Named admin identity, MFA, least-privilege permission and short privileged session
Mutation	Reason code mandatory; before/after summary and correlation ID written to append-only audit log
Sensitive files	On-demand signed URL, watermark/download event where practical; no permanent public link
Acceptance	Permission matrix tests prove verifier/support/super-admin separation

2.27 PHASE 1 ADMIN

Audit and Support

Privileged operations for audit and support.

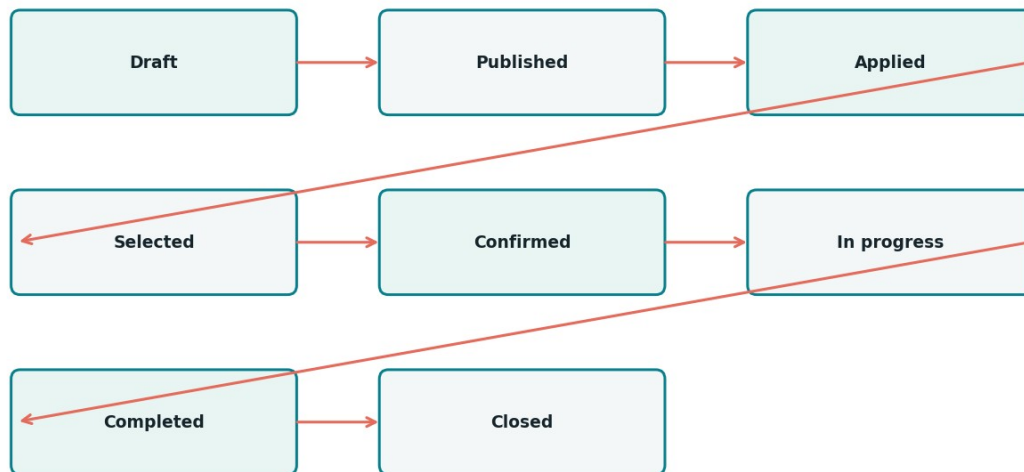
Area	Implementation contract
Display	Actor, action, target, time, reason, correlation ID, redacted metadata
Actions	Search; export authorized subset; attach support outcome
Access	Named admin identity, MFA, least-privilege permission and short privileged session
Mutation	Reason code mandatory; before/after summary and correlation ID written to append-only audit log
Sensitive files	On-demand signed URL, watermark/download event where practical; no permanent public link
Acceptance	Permission matrix tests prove verifier/support/super-admin separation

3. PHASE 1 BEHAVIOR

Duty Lifecycle State Machine

The database stores one canonical state; UI labels are projections. Every transition is atomic and audited.

CANONICAL DUTY LIFECYCLE



From	Allowed action	To	Actor / guard
draft	publish	published	Verified hospital; valid future schedule
published	apply	application.submitted	Eligible verified doctor; duty open
submitted	shortlist/reject	shortlisted/rejected	Same organization
shortlisted	select	selected	Capacity available; atomic assignment lock
selected	accept	confirmed	Selected doctor before expiry
confirmed	start	in_progress	Time/geofence policy or admin exception
in_progress	complete	completed	Completion evidence recorded
completed	close	closed	Feedback/payment acknowledgment optional, not blocking

3. PHASE 1 BEHAVIOR

Concurrency and Double-booking Rules

Selection is a contested write. Correctness must not depend on two clients refreshing at the same time.

Atomic selection

- Run selection in one transaction or database function.
- Lock duty capacity/assignment row and check current version.
- Insert assignment and transition selected application atomically.
- Reject stale contenders with HTTP 409 and current state.
- Emit one outbox event only after commit.

Doctor conflict

- Prevent overlapping confirmed assignments using server-side interval check; use exclusion constraint when feasible.
- Allow admin override only with explicit reason and audit trail.
- Idempotency key makes retries safe after network timeout.

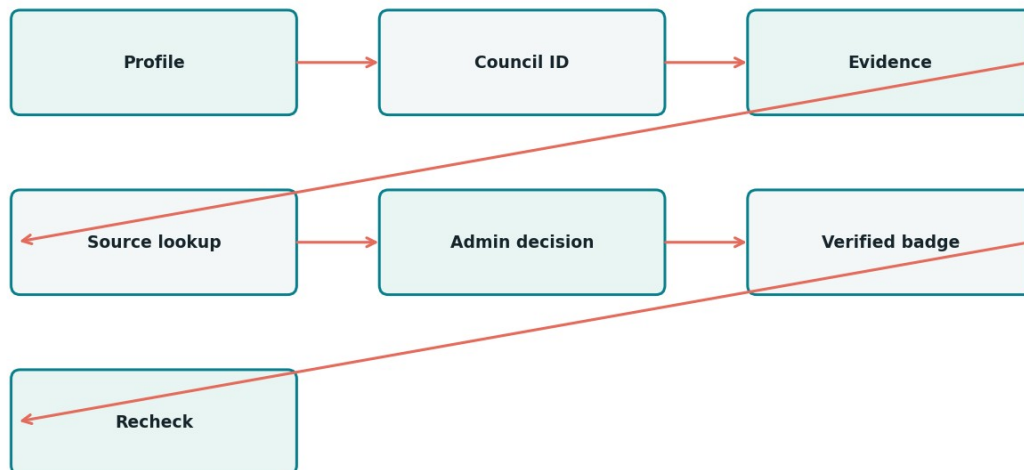
TEST A 25-client concurrent selection test must produce no duplicate assignment and a deterministic capacity result.

3. PHASE 1 BEHAVIOR

Doctor Verification Procedure

Verification establishes that the submitted professional identity and registration evidence match an official source record; it is not a permanent guarantee of fitness or conduct.

DOCTOR VERIFICATION CASE



Step	System behavior	Evidence retained
Normalize	Capture council, registration number, name and qualification in canonical form	Input snapshot + hash
Document	Private upload of registration proof and identity-supporting evidence	Object key, MIME, size, SHA-256, scan result
Official lookup	Verifier checks NMC Indian Medical Register/National Medical Register or relevant State Medical Council source	Source, timestamp, query and result summary
Match	Compare name, registration, council, qualification and status; flag discrepancies	Field-level check results
Decision	Approve, reject, request information or escalate	Reviewer, reason code, note and version
Recheck	Reverify on expiry, material profile change, complaint or policy interval	New case linked to prior case

INTEGRATION RULE Do not scrape protected sources or imply an official API exists. Implement a verification-source adapter so an authorized council API can replace manual lookup later.

3. PHASE 1 BEHAVIOR

Verification Status and Badge Rules

A badge is a computed view of a current approved case and matching profile version; never store it as an independently editable boolean.

Status	User-facing meaning	Allowed marketplace behavior
draft	Evidence not submitted	Browse only; no application to restricted duties
submitted	Awaiting review	Configurable pilot access; never show verified badge
needs_information	Additional evidence required	Resume case; restricted actions
under_review	Verifier is checking	No badge
approved	Evidence matched at decision time	Verified badge; eligible by duty policy
rejected	Requirements not met or mismatch	Reason category + appeal route
expired/suspended	Approval no longer active	Badge removed immediately; active assignment handled by admin policy

3. PHASE 1 BEHAVIOR

Notification Architecture

Notifications are a delivery channel, not the source of truth. The app always resolves the latest record after opening a push.

Event	Recipients	Channel	Delivery rule
duty.published	Matching opted-in doctors	FCM + inbox	Fan-out asynchronously; deduplicate by event/user
application.submitted	Hospital duty managers	FCM + inbox	Aggregate noisy alerts
application.selected	Selected doctor	FCM + inbox	High priority; expiry displayed from server time
assignment.confirmed	Doctor + hospital	FCM + inbox	Transactional; cannot be marketing-suppressed
verification.updated	Case owner	FCM + inbox	No sensitive reason in lock-screen body
delivery.failed	Operations	Alert/dashboard	Retry exponential backoff; dead-letter after threshold

OUTBOX Domain transaction writes notification_outbox. Worker claims rows, sends FCM, stores delivery_attempts and never rolls back the committed business action.

3. PHASE 1 BEHAVIOR

Location, Maps and Contact Release

Location supports discovery and navigation while minimizing exposure of precise personal data.

Location model

- Facility stores verified latitude/longitude and human-readable address.
- Doctor stores preferred work areas; precise live location is not required for Phase 1.
- Nearby search uses server-side geospatial query and returns rounded distance.
- Navigation hands off to Google Maps intent; no continuous tracking.

Contact privacy

- Public duty cards do not expose personal phone numbers.
- Contact details become available only after confirmed assignment under a recorded `contact_grant`.
- Views/downloads of sensitive contact data are auditable.
- Support can revoke access when an assignment is cancelled.

3. PHASE 1 BEHAVIOR

Payment Terms and Acknowledgment - No Gateway

Phase 1 records agreed duty terms and whether parties acknowledged payment. The platform does not hold funds, guarantee settlement or perform escrow.

Data	Purpose	Rule
payment_terms_snapshot	Preserve agreed amount basis, method and expected timing	Immutable after doctor confirmation; amendments create version
payment_status	Track pending/acknowledged/disputed	Not equivalent to bank settlement confirmation
acknowledged_by	Record hospital/doctor acknowledgment	Actor and timestamp required
evidence_reference	Optional receipt/reference	Private access and retention rule
gateway_adapter	Reserved interface for later authorized payment activation	Disabled feature flag; secrets only server-side

COMMERCIAL EXCLUSION This architecture contains no payment amount recommendation, gateway fee, subscription price or revenue commitment.

3. PHASE 1 BEHAVIOR

Moderation, Complaints and Support

Safety operations need structured cases, not free-form deletion powers.

Case type	Minimum fields	Permitted outcome
False duty	Reporter, duty, category, evidence, urgency	Hide pending review; restore; suspend poster
Identity concern	Subject, linked verification, evidence	Open recheck; suspend badge
Conduct issue	Assignment, structured category, narrative, evidence	Warn; restrict; escalate
Payment dispute	Terms snapshot, acknowledgments, evidence	Record/mediate; no false guarantee of recovery
Appeal	Decision, appellant, grounds, new evidence	Independent review; uphold/reverse

4. PHASE 2

Trusted Workforce Network Scope

Phase 2 converts completed duty activity into operational trust while adding mechanisms for availability, cancellation recovery and fair dispute handling.

Capability	User value	Foundation required from Phase 1
Availability	Doctors declare when and where they can work	Stable doctor IDs, specialties, location taxonomy
Last-minute alerts	Urgent matching without group spam	Outbox, preferences, device tokens
Reliability	Explainable completion behavior	Immutable assignment events
Replacement	Recover from cancellation	Assignment state machine and capacity locks
Duty wallet	Personal duty/payment history	Terms snapshots and acknowledgments
Disputes/appeals	Fair review with evidence	Audit logs and moderation roles
Entitlements	Feature access can be configured	Feature flags and entitlement table; no pricing in scope

4.2 PHASE 2

Availability Calendar

Phase 2 implementation contract for availability calendar.

Contract	Specification
Fields / display	One-time and recurring availability, preferred shifts, locations and specialties
Actions	Create rule; add exception; pause; copy week
Data	availability_rules, availability_exceptions
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.3 PHASE 2

Last-minute Duty Alerts

Phase 2 implementation contract for last-minute duty alerts.

Contract	Specification
Fields / display	Urgency, distance, match reason, expiry, facility trust
Actions	Open; apply; mute category; snooze
Data	duty_match_candidates, notification_outbox, preferences
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.4 PHASE 2

Duty History and Wallet

Phase 2 implementation contract for duty history and wallet.

Contract	Specification
Fields / display	Completed duties, terms snapshot, acknowledgment state, downloadable record
Actions	Filter; view; add acknowledgment/evidence; raise dispute
Data	assignments, completion_records, payment_acknowledgements
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.5 PHASE 2

Reliability Profile

Phase 2 implementation contract for reliability profile.

Contract	Specification
Fields / display	Completion, punctuality, cancellation and response dimensions with sample size
Actions	View explanation; report error; appeal source event
Data	reliability_snapshots, reliability_dimensions
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.6 PHASE 2

Cancellation and Replacement

Phase 2 implementation contract for cancellation and replacement.

Contract	Specification
Fields / display	Cancellation category, notice duration, replacement status and action timer
Actions	Cancel with reason; request replacement; accept reassignment
Data	replacement_requests, replacement_candidates, assignment_events
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.7 PHASE 2

Dispute and Appeal Center

Phase 2 implementation contract for dispute and appeal center.

Contract	Specification
Fields / display	Case timeline, issue category, evidence, status and decision
Actions	Open; upload; respond; appeal once
Data	disputes, dispute_evidence, dispute_events, appeals
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.8 PHASE 2

Hospital Trust View

Phase 2 implementation contract for hospital trust view.

Contract	Specification
Fields / display	Operational reliability dimensions and verified experience relevant to duty
Actions	Review evidence-backed summary; select; report inconsistency
Data	reliability_snapshots, assignments, verification_cases
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.9 PHASE 2

Entitlement-aware Features

Phase 2 implementation contract for entitlement-aware features.

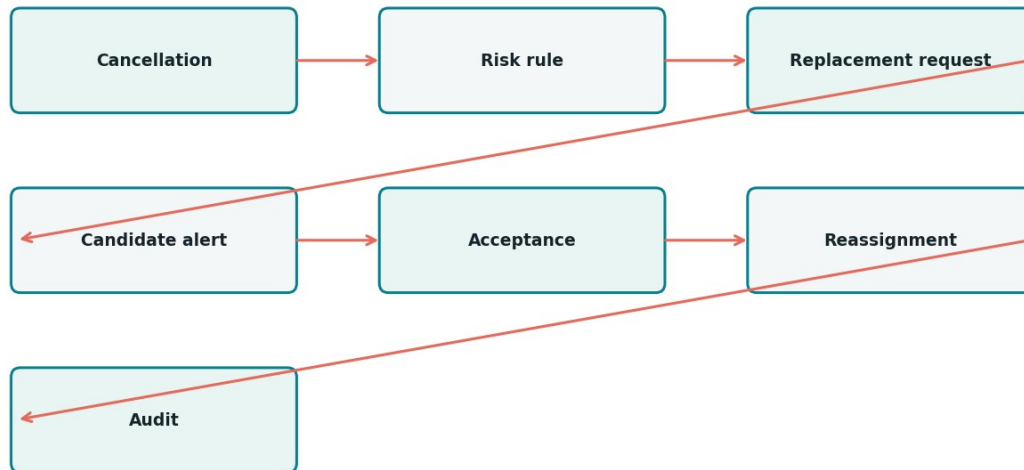
Contract	Specification
Fields / display	Current plan/entitlement labels and feature availability
Actions	Access enabled module; restore entitlement; contact support
Data	plans, entitlements, entitlement_events
Server rule	All calculated trust/eligibility values are server-derived, versioned and explainable
Privacy	Show minimum information needed for the current duty decision; no public ranking leaderboard
Acceptance	Deterministic calculation test + authorization test + appeal/recovery path + feature-flag test

4.10 PHASE 2

Replacement State Machine

Replacement is a controlled reassignment, not a second unlinked duty post. The original assignment history remains immutable.

PHASE 2 REPLACEMENT WORKFLOW



State	Allowed next state	Guard
requested	searching / cancelled	Eligible cancellation reason; duty not ended
searching	candidate_offered / failed	Candidate query uses availability and verification
candidate_offered	accepted / expired / declined	Single active offer or configured wave
accepted	reassigned	Atomic conflict/capacity check
reassigned	closed	New assignment confirmed; old assignment marked replaced
failed	manual_escalation / closed	No eligible candidate before cutoff

4.11 PHASE 2

Reliability Calculation Contract

Reliability is a set of operational dimensions with confidence context. It must not claim clinical quality or become a popularity score.

Dimension	Source events	Display rule
Completion	confirmed vs completed assignments	Rate + completed sample size
Punctuality	agreed start vs acknowledged start	Band; exclude approved exceptions
Cancellation	actor, notice window, reason outcome	Separate avoidable and excused categories
Response	offer sent/accepted/expired	Rolling window; do not punish muted periods
Feedback	structured post-duty categories	Aggregate only after minimum sample threshold

EXPLAINABILITY Every displayed dimension must resolve to the underlying eligible events, policy version and appeal route.

4.12 PHASE 2

Doctor Pro Entitlement Contract - No Pricing

Phase 2 may expose configurable professional productivity benefits through entitlements. Verification, basic duty access and safety-critical notifications must never depend on payment.

Entitlement	Developer behavior	Fairness guard
advanced_filters	Enable saved multi-condition duty filters and reusable search presets	Does not hide eligible duties from standard users
calendar_sync	Export/subscribe to confirmed duty and availability calendar events	No access to another user's schedule
professional_analytics	Show private duty-history and response/completion trends	No clinical-performance claim
document_vault	Offer organized reuse of already verified professional documents	Private storage and expiry/review rules remain
priority_support	Route support case to configured queue	Does not bypass verification or moderation policy
enhanced_alert_controls	Additional saved alert profiles and quiet-hour exceptions	Urgent access remains eligibility-based, not pay-to-win

ENTITLEMENT SOURCE The client reads effective entitlements from /v1/me. It never decides access from a locally stored subscription label.

4.13 PHASE 2

Payment Gateway Adapter and Webhook Contract

If subscriptions are activated after a separate business/legal decision, integrate through one server-side adapter. No gateway, fee, price or payment commitment is selected by this architecture.

Component	Contract
PaymentProvider	create_order, fetch_status, verify_webhook, refund_or_void where enabled; provider-neutral DTOs
Provider options	Razorpay or Cashfree for India-focused activation; Stripe-compatible adapter reserved for later supported expansion
Order	Server creates provider order from an approved plan key; client never supplies authoritative amount/entitlement
Checkout	Provider SDK/session receives short-lived order token; no secret key in Flutter
Webhook	Verify signature against raw body, enforce timestamp/replay rule, store event ID and process idempotently
Ledger	payment_orders, payment_transactions, webhook_events and entitlement_events preserve immutable state history
Activation	Entitlement changes only after server-confirmed terminal success; pending/failed states grant nothing
Reconciliation	Scheduled job compares provider status and local ledger; mismatch opens operations alert

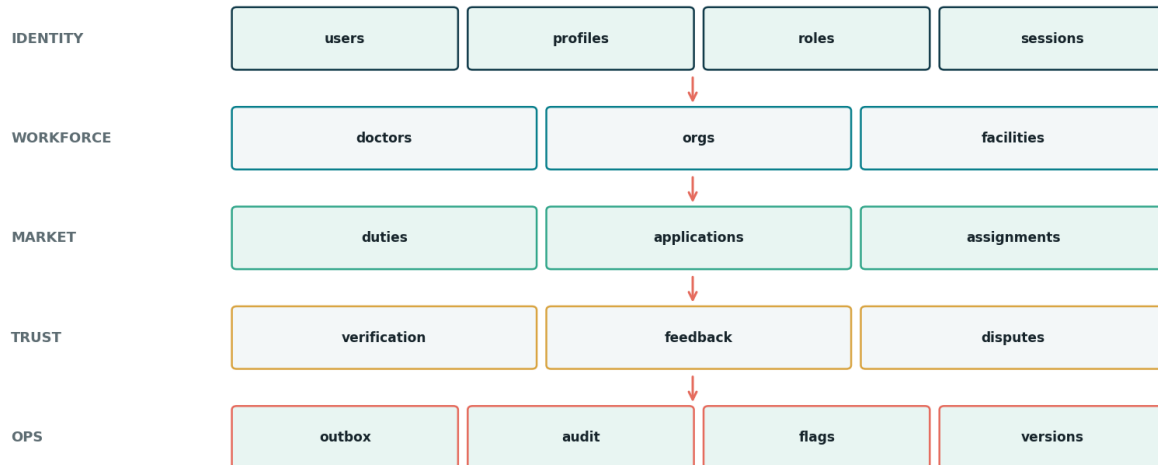
CURRENT SCOPE Gateway execution remains disabled behind a server feature flag. Phase 1 duty payments remain acknowledgments only; the platform does not hold duty funds or provide escrow.

5. DATA

Logical Data Architecture

PostgreSQL is the source of truth. Tables are grouped by domain and connected with stable UUIDs, timestamps and explicit ownership.

LOGICAL DATA DOMAINS



5.2

Identity and Access Tables

Required tables and their ownership intent. Detailed migrations may add technical columns but must preserve these domain boundaries.

Table	Core columns	Responsibility
users	id, phone/email, status, created_at	Auth identity link
profiles	user_id, display_name, locale, city	Non-role personal profile
role_memberships	user_id, role, organization_id, status	Authorization claims
sessions	user_id, device_id, revoked_at, risk	Session control
consent_records	user_id, notice_version, purpose, accepted_at	Auditable consent

5.3

Doctor and Organization Tables

Required tables and their ownership intent. Detailed migrations may add technical columns but must preserve these domain boundaries.

Table	Core columns	Responsibility
doctors	user_id, council, registration_no_norm, experience	Professional identity
doctor_qualifications	doctor_id, qualification, institution, year	Credential detail
doctor_specialties	doctor_id, specialty_id, primary	Matching
organizations	id, legal_name, type, verification_state	Tenant root
organization_members	organization_id, user_id, permission_set	Scoped access
facilities	organization_id, address, geo, status	Duty location

5.4

Marketplace Tables

Required tables and their ownership intent. Detailed migrations may add technical columns but must preserve these domain boundaries.

Table	Core columns	Responsibility
duties	organization_id, facility_id, specialty_id, schedule, status, version	Current duty
duty_versions	duty_id, version, snapshot, actor	Immutable terms history
applications	duty_id, doctor_id, status, version	Candidate workflow
application_snapshots	application_id, profile_snapshot	Review-time facts
assignments	duty_id, doctor_id, terms_version, status	Selected work
assignment_events	assignment_id, from/to, actor, reason	Canonical history

5.5

Verification and Trust Tables

Required tables and their ownership intent. Detailed migrations may add technical columns but must preserve these domain boundaries.

Table	Core columns	Responsibility
verification_cases	subject_type/id, status, policy_version	Case root
verification_checks	case_id, check_type, source, result	Field/source checks
verification_documents	case_id, object_key, hash, scan_status	Private evidence metadata
feedback	assignment_id, author/subject, dimensions	Structured feedback
reliability_snapshots	subject_id, version, window, score_json	Calculated dimensions
disputes	assignment_id, category, state	Phase 2 case

5.6

Operations and Platform Tables

Required tables and their ownership intent. Detailed migrations may add technical columns but must preserve these domain boundaries.

Table	Core columns	Responsibility
notification_outbox	event_type, aggregate_id, payload_ref, state	Reliable dispatch
delivery_attempts	outbox_id, channel, attempt, result	Delivery evidence
device_tokens	user_id, token_hash, platform, active	Push routing
audit_logs	actor, action, target, reason, metadata	Immutable audit
feature_flags	key, cohort_rule, value, version	Staged release
app_versions	platform, min/current version, force flag	Compatibility

5.7

Phase 2 Tables

Required tables and their ownership intent. Detailed migrations may add technical columns but must preserve these domain boundaries.

Table	Core columns	Responsibility
availability_rules	doctor_id, recurrence, timezone, preferences	Recurring schedule
availability_exceptions	rule/doctor, date interval, available	Overrides
replacement_requests	assignment_id, reason, status, deadline	Recovery case
replacement_candidates	request_id, doctor_id, state, rank_reason	Offers
payment_acknowledgements	assignment_id, actor, state, reference	Wallet record
dispute_evidence	dispute_id, object_key, hash	Private evidence
appeals	decision_type/id, appellant, grounds, status	Independent review

5.8 DATA

Keys, Constraints and Index Strategy

Database constraints defend invariants even when a client or function contains a bug.

Required constraints

- UUID primary keys; timestampz in UTC; created_by/updated_by where ownership matters.
- Unique normalized council + registration number for active doctor identity, subject to verified exception workflow.
- Unique doctor_id + duty_id active application.
- Check constraints for time order, enumerations and non-negative headcount.
- Foreign keys use deliberate delete behavior; business history normally restricts or soft-deletes.

Indexes

- | | |
|---|--|
| • duties(status, start_at, specialty_id, facility_id) | • applications(duty_id, status, created_at) |
| • assignments(doctor_id, start_at, end_at, status) | • verification_cases(status, submitted_at) |
| • notification_outbox(state, available_at) | • audit_logs(target_type, target_id, created_at) |

5.9 DATA

RLS Policy Model

Every exposed table enables RLS before production data exists. Service-role access is restricted to server runtime and never shipped to clients.

Resource	Doctor	Hospital member	Admin
doctor profile	Own read/write allowed fields	Selected public snapshot only	Permissioned review
organization/facility	Published verified fields	Own tenant by membership	Permissioned review
duty	Published eligible read	Own tenant CRUD by permission	Moderation read/write
application	Own rows	Rows for own duties	Support by permission
assignment	Own assigned rows	Own organization rows	Support by permission
verification document	Own case via signed URL	Own org case via signed URL	Verifier only, audited
audit log	No direct access	No direct access	Filtered role access

5.10 DATA

Migration, Seed and Retention Rules

Schema evolution must support old and new mobile versions during staged Play Store rollout.

Migration discipline

- Numbered SQL migrations committed with application code.
- Prefer expand -> backfill -> switch -> contract; never rename/drop in the same release used by old clients.
- Rehearse against production-like data volume in staging.
- Rollback is a forward corrective migration for committed production changes.

Seed/config

- Reference specialties, councils, cities, roles and reason codes use stable keys.
- Environment-specific secrets are never seed data.
- Test fixtures contain synthetic identities and documents only.

Retention

- Define retention by data class; delete/anonymize when purpose expires unless legal/operational hold applies.
- Audit/security records have separate retention and access policy.
- Account deletion is an orchestrated job, not raw cascading deletion.

6. API

API Design Standard

The Flutter client consumes typed, versioned contracts. Complex mutations use server functions or RPC endpoints; simple reads may use Supabase APIs under RLS.

Rule	Contract
Namespace	/v1 for server endpoints; schema DTO version recorded where needed
Authentication	Bearer access token; server derives user/roles; never accepts actor_id as authority
Idempotency	Idempotency-Key required for application, selection, confirmation and payment acknowledgment writes
Concurrency	expected_version required for contested updates; stale request returns 409
Pagination	Cursor-based with stable sort and bounded page size
Time	ISO-8601 UTC over wire; timezone captured for recurring availability
Errors	Stable code, safe message, correlation_id, field_errors; no stack trace

6.2

Authentication and Session APIs

Minimum endpoint inventory. Endpoint implementation may use Edge Functions or a Node service, but semantics and authorization remain stable.

Method	Route	Purpose
POST	/v1/auth/otp/request	Request rate-limited OTP
POST	/v1/auth/otp/verify	Create/rotate session
POST	/v1/auth/refresh	Rotate refresh token
POST	/v1/auth/logout	Revoke current session
GET	/v1/me	Identity, roles, entitlements, app config
POST	/v1/consents	Record notice acceptance

6.3

Doctor and Verification APIs

Minimum endpoint inventory. Endpoint implementation may use Edge Functions or a Node service, but semantics and authorization remain stable.

Method	Route	Purpose
GET	/v1/doctors/me	Own profile
PUT	/v1/doctors/me	Versioned profile update
POST	/v1/verifications	Create case
POST	/v1/verifications/{id}/uploads	Issue signed upload intent
POST	/v1/verifications/{id}/submit	Submit complete case
GET	/v1/verifications/{id}	Case timeline
POST	/v1/verifications/{id}/appeals	Phase 2 appeal

6.4

Duty and Application APIs

Minimum endpoint inventory. Endpoint implementation may use Edge Functions or a Node service, but semantics and authorization remain stable.

Method	Route	Purpose
GET	/v1/duties	Filter/cursor list
GET	/v1/duties/{id}	Eligible duty detail
POST	/v1/duties	Hospital draft
POST	/v1/duties/{id}/publish	Validated transition
POST	/v1/duties/{id}/applications	Idempotent apply
PATCH	/v1/applications/{id}	Withdraw/shortlist/reject
POST	/v1/applications/{id}/select	Atomic selection

6.5

Assignment and Completion APIs

Minimum endpoint inventory. Endpoint implementation may use Edge Functions or a Node service, but semantics and authorization remain stable.

Method	Route	Purpose
POST	/v1/assignments/{id}/confirm	Doctor acceptance
POST	/v1/assignments/{id}/start	Start acknowledgment
POST	/v1/assignments/{id}/complete	Completion record
POST	/v1/assignments/{id}/feedback	Structured feedback
POST	/v1/assignments/{id}/payment-ack	Record acknowledgment
POST	/v1/assignments/{id}/report	Open support case

6.6

Phase 2 Trust APIs

Minimum endpoint inventory. Endpoint implementation may use Edge Functions or a Node service, but semantics and authorization remain stable.

Method	Route	Purpose
GET	/v1/availability	Own calendar
POST	/v1/availability/rules	Recurring rule
POST	/v1/availability/exceptions	Date override
POST	/v1/assignments/{id}/replacement	Request replacement
POST	/v1/replacements/{id}/accept	Atomic reassignment
GET	/v1/reliability/{subject}	Explainable dimensions
POST	/v1/disputes	Open case
POST	/v1/disputes/{id}/evidence	Signed evidence upload

6.7

Admin APIs

Minimum endpoint inventory. Endpoint implementation may use Edge Functions or a Node service, but semantics and authorization remain stable.

Method	Route	Purpose
GET	/v1/admin/verifications	Permissioned queue
POST	/v1/admin/verifications/{id}/claim	Claim case
POST	/v1/admin/verifications/{id}/decision	Reasoned decision
GET	/v1/admin/reports	Moderation queue
POST	/v1/admin/moderation/{id}/action	Audited action
PUT	/v1/admin/config/{key}	Versioned config
GET	/v1/admin/audit	Filtered audit search

6.8 API

Error Envelope and Status Codes

Errors must be actionable to the client and safe for logs and users.

HTTP	Stable code example	Client behavior
400	VALIDATION_FAILED	Show field errors; preserve input
401	SESSION_EXPIRED	Attempt one refresh; otherwise re-authenticate
403	ACTION_NOT_ALLOWED	Hide unsafe detail; refresh permissions
404	RESOURCE_NOT_FOUND	Use same response for inaccessible sensitive resources
409	VERSION_CONFLICT / CAPACITY_FILLED	Refresh record and explain conflict
422	TRANSITION_INVALID	Display current state and permitted action
429	RATE_LIMITED	Respect retry_after; no aggressive loop
500	INTERNAL_ERROR	Show correlation ID; retry only idempotent action

ENVELOPE { error: { code, message, correlation_id, field_errors?, retry_after? } }. Never return SQL, secrets, stack traces or council-document contents.

6.9 API

File Upload Contract

Verification and dispute evidence use direct-to-private-storage signed uploads with server-controlled metadata finalization.

Sequence

- Client requests upload intent with filename, MIME and size.
- Server validates case ownership and returns short-lived signed upload target.
- Client uploads bytes; storage event or finalize endpoint records object metadata.
- Scanner validates malware/type; server computes/records SHA-256 where supported.
- Only clean object becomes reviewable through a short-lived signed read URL.

Controls

- Allowlisted MIME/extensions; magic-byte validation; strict size limits.
- Opaque object key; no user filename in public path.
- Quarantine bucket/prefix until scan completes.
- Downloads audited for privileged reviewers; URLs expire quickly.

6.10 API

Domain Events and Analytics Taxonomy

Business events support notifications, reliability calculation and product measurement. Analytics must never contain document contents or unnecessary identifiers.

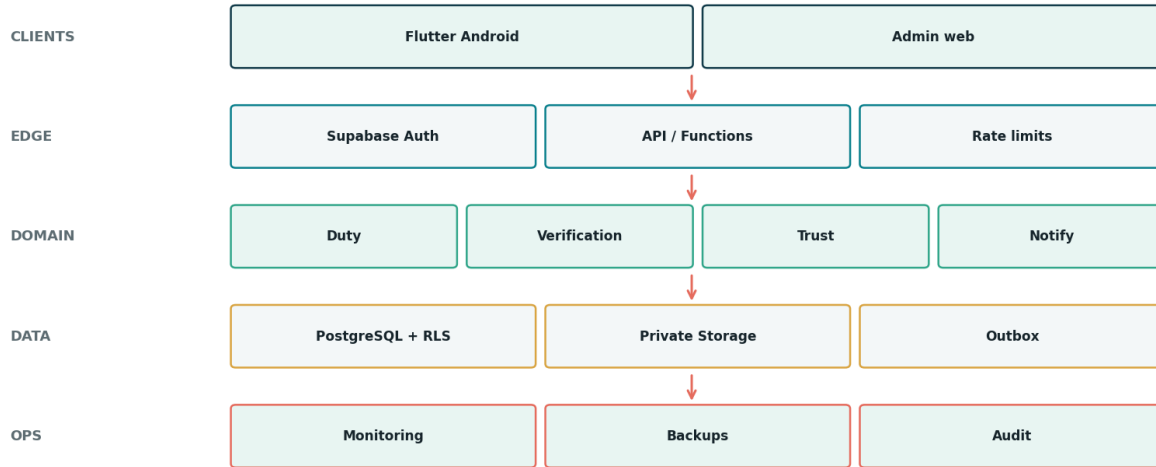
Event family	Examples	Consumers
identity	consent.accepted, session.revoked	Security/analytics
verification	case.submitted, check.completed, case.decided	Inbox/admin/audit
duty	duty.published, duty.closed	Matching/analytics
application	application.submitted, shortlisted, selected	Notifications/metrics
assignment	confirmed, started, completed, cancelled	Trust/wallet/alerts
replacement	requested, offered, accepted, failed	Phase 2 operations
dispute	opened, evidence_added, decided, appealed	Support/audit

7. SECURITY

Deployment and Service Architecture

The selected stack minimizes operational overhead while enforcing clear privilege boundaries.

DEPLOYMENT ARCHITECTURE



Runtime components

- Flutter Android app with typed repository layer and secure local token handling.
- Browser admin portal; current implementation may use modular HTML/CSS/JavaScript, with API contracts compatible with later Next.js migration.
- Supabase Auth, PostgreSQL, RLS, private Storage and Edge Functions; Node.js service can be introduced when long-running integration needs justify it.
- FCM for push and Google Maps intents for navigation.

7. SECURITY

Threat Model and Trust Boundaries

Assume a hostile client, stolen token, malicious upload, compromised low-privilege account and accidental operator error.

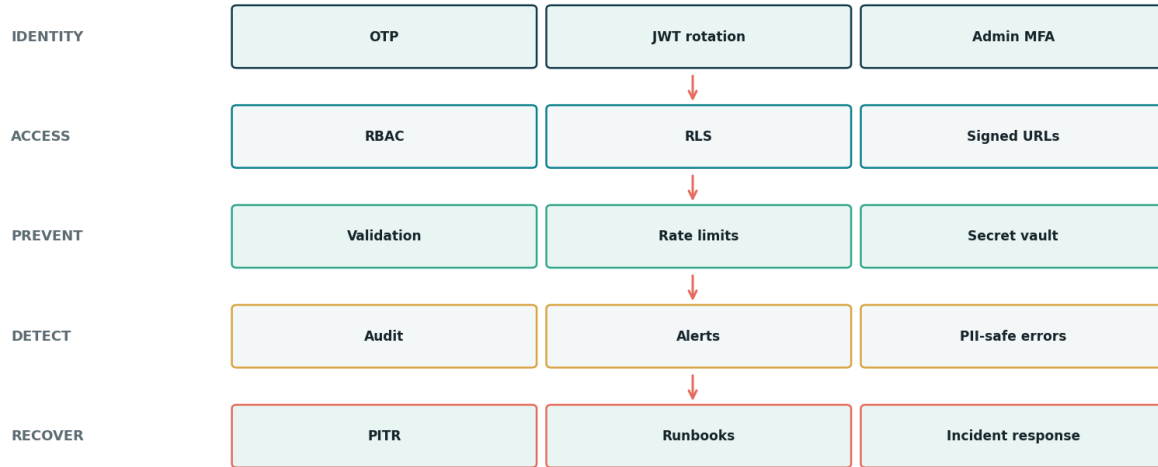
Threat	Primary controls	Verification
Cross-tenant access	RLS, organization membership, object policy	Negative authorization suite
Account takeover	OTP limits, token rotation, device/session revocation, admin MFA	Abuse and session tests
Privilege escalation	Server-derived roles, least privilege, step-up, audit	Role matrix tests
Malicious document	Private quarantine, type/size checks, malware scan	EICAR-safe scanner test
API abuse	Rate limits, validation, App Check/Play Integrity signal	DAST and abuse simulation
Data exfiltration	Minimization, signed URLs, secrets vault, alerting	Log and storage audit
Insider misuse	Named accounts, reason codes, restricted exports, immutable audit	Quarterly access review

7. SECURITY

Defense-in-Depth Control Stack

No single control is treated as sufficient for sensitive professional identity data.

DEFENSE IN DEPTH



7.4

Authentication and Session Security

Mandatory controls for authentication and session security.

Implementation requirements

- OTP request/verify limits by phone, IP, device and velocity; generic account-existence responses.
- Short-lived access tokens; refresh rotation; reuse detection and server-side revocation.
- Store mobile secrets/tokens in platform secure storage; no tokens in logs or analytics.
- Admin requires MFA and step-up for verification decision, export, suspension and role change.
- Session inventory enables user/admin revocation; risky device changes trigger re-authentication.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.5

Authorization, RLS and Storage Security

Mandatory controls for authorization, rls and storage security.

Implementation requirements

- RBAC answers capability; RLS answers which rows; both are required.
- Policies use auth.uid() plus active role/organization membership, not client-provided organization IDs alone.
- Private buckets only; signed reads are short-lived and case-scoped.
- Service-role key exists only in server secret manager and is unavailable to Flutter/admin browser code.
- Run automated RLS tests for every role/resource/action combination before migration promotion.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.6

Application and API Security

Mandatory controls for application and api security.

Implementation requirements

- Validate schemas server-side; parameterized queries; output encoding; safe file names.
- CSRF protection for cookie-based admin sessions; strict CORS allowlist and security headers.
- Rate-limit authentication, search, application, upload and admin decision endpoints separately.
- Idempotency and optimistic concurrency defend replay and race conditions.
- Dependency pinning, lockfiles and software-bill-of-materials artifact per release.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.7

Secrets, Encryption and Privacy

Mandatory controls for secrets, encryption and privacy.

Implementation requirements

- TLS for all network traffic; managed encryption at rest for database/storage/backups.
- Secrets stored in environment/secret vault; rotation runbook and least-privilege integration credentials.
- Mask phone/email in admin lists; reveal only when workflow requires it.
- Separate operational logs from sensitive records; PII scrubbing in Sentry and log pipeline.
- Consent/purpose/retention records support privacy requests and prevent silent repurposing of community data.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.8

Security Toolchain

Mandatory controls for security toolchain.

Implementation requirements

- Gitleaks or TruffleHog for secret scanning in pre-commit/CI.
- Semgrep and/or CodeQL for SAST; OSV-Scanner or Snyk for dependency risk.
- OWASP ZAP for staging DAST; MobSF for Android static/dynamic review.
- OWASP MASVS guides mobile controls; OWASP ASVS guides API/admin verification.
- k6 for abuse/concurrency/load; Sentry with PII scrubbing for runtime errors.
- Firebase App Check and Play Integrity signals may increase abuse resistance but do not replace server authorization.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.9

Audit, Monitoring and Alerting

Mandatory controls for audit, monitoring and alerting.

Implementation requirements

- Audit actor, action, target, reason, result, time, IP/device risk metadata and correlation ID.
- Never place raw document contents, OTPs, tokens or full sensitive profiles in logs.
- Alert on repeated OTP abuse, cross-tenant denials, mass downloads, role changes, verification spikes and webhook signature failures.
- Dashboards track API error/latency, notification backlog, scanner failures, database saturation and crash-free sessions.
- Operational alerts name owner, severity, runbook and acknowledgment path.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.10

Backups, Recovery and Incident Response

Mandatory controls for backups, recovery and incident response.

Implementation requirements

- Automated database backups/PITR according to enabled managed plan; private storage version/backup strategy documented.
- Quarterly restore drill in isolated environment with measured recovery time and integrity checks.
- Incident phases: detect, triage, contain, preserve evidence, eradicate, recover, notify, learn.
- Revoke sessions/keys, disable affected feature flag and preserve immutable audit during containment.
- Maintain contact tree, decision log, communication templates and post-incident corrective actions.

Release evidence

- Configuration screenshot/export with secrets redacted
- Automated test or scan result
- Named owner and runbook
- Accepted residual-risk record for any deferred medium/low issue

7.11 SECURITY

Data Classification and Handling

Controls scale with sensitivity. Patient health records are prohibited in Phase 1 and Phase 2.

Class	Examples	Handling
Public	Published duty summary, verified facility name	Cacheable after moderation; no personal contact
Internal	Aggregated metrics, configuration	Authenticated staff; controlled export
Confidential	Phone/email, applications, assignments	RLS, encryption, masked admin display
Highly confidential	Identity/registration documents, dispute evidence	Private storage, signed access, reviewer restriction, audit
Prohibited	Patient case sheets, diagnoses, prescriptions, clinical media	Do not collect; block/report accidental upload

8. ENGINEERING

Flutter Application Architecture

Use feature-first modules with clear Presentation, Application, Domain and Data boundaries. Riverpod is the selected state-management and dependency-injection pattern.

Layer	Responsibility	Examples
presentation	Widgets, navigation, form state, view models	DutyListPage, AsyncValue states
application	Use-case orchestration and commands	ApplyToDuty, ConfirmAssignment
domain	Entities, value objects, policies, repository interfaces	DutyStatus, TimeRange
data	DTOs, Supabase/API clients, repository implementations	DutyDto, VerificationRemoteDataSource
core	Auth/session, networking, errors, config, telemetry, design system	ApiClient, AppRouter

CLIENT RULE UI may predict eligibility for responsiveness, but it must handle server rejection and refresh canonical state.

8. ENGINEERING

Repository and Project Structure

Keep deployable applications and database artifacts in one versioned workspace or coordinated repositories with the same release tag.

Path	Contents
/mobile/lib/core	config, auth, routing, network, errors, telemetry, design system
/mobile/lib/features	auth, profile, verification, duties, applications, assignments, trust, settings
/admin	modular HTML/CSS/ES modules; auth guard; API client; verification/moderation/config views
/backend/functions	versioned server functions/RPC adapters and outbox workers
/database/migrations	ordered SQL migrations, RLS policies, functions, constraints, indexes
/database/tests	pgTAP/SQL authorization and state-transition tests
/docs	OpenAPI, ADRs, threat model, runbooks, data dictionary
/testing	integration fixtures, k6, ZAP config, device matrix

8. ENGINEERING

Environment and Configuration Strategy

Development, staging and production use separate projects, credentials, storage and notification configuration.

Environment	Purpose	Data rule	Release rule
local/dev	Feature development	Synthetic only	Debug signing; relaxed notification routing
test	Automated integration	Resettable fixtures	CI-controlled
staging	Production-like QA/security/load	Synthetic or consented test accounts	Same migrations/build candidate
production	Controlled pilot and rollout	Real purpose-limited data	Manual approval + immutable release tag

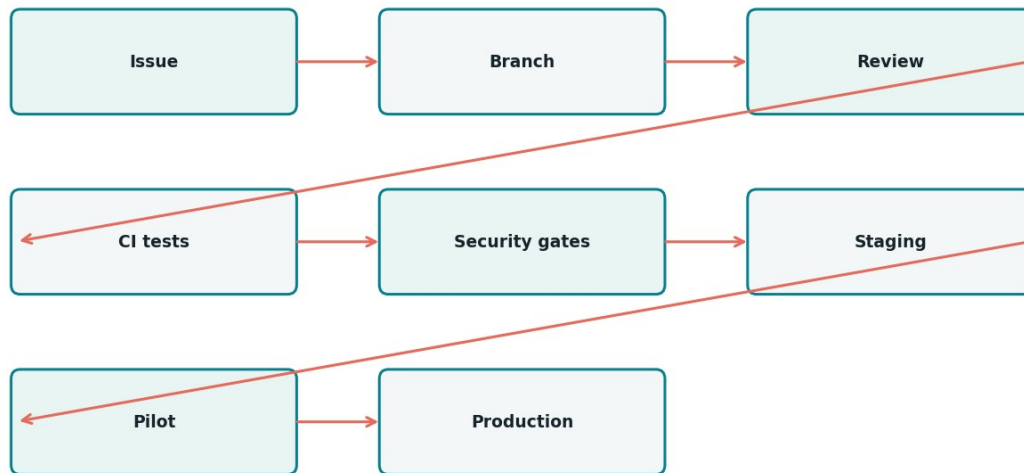
CONFIGURATION Use typed environment config and remote feature flags. Fail closed if required security configuration is missing.

8. ENGINEERING

CI/CD Pipeline and Quality Gates

A release candidate is reproducible from source, migration version and environment configuration.

ENGINEERING DELIVERY PIPELINE



Gate	Required checks
Pull request	Format, lint, unit tests, secret scan, SAST, dependency scan
Integration	API contract, database migration, RLS negative tests, storage-policy tests
Mobile	Widget/integration tests, signed build, MobSF, device smoke
Staging	ZAP, k6, notification test, backup/restore readiness, UAT
Production	Change approval, rollback/kill switch, monitoring owner, release notes

8. ENGINEERING

Testing Strategy

Testing follows the risk: authorization, contested writes and lifecycle transitions receive deeper coverage than cosmetic screens.

Level	Coverage	Examples
Unit	Value objects, eligibility, reliability calculation	Time overlap, policy versions
Widget	Forms, states, accessibility	OTP, duty filters, upload progress
API integration	Auth, validation, transition, idempotency	Duplicate apply retry
Database	Constraints, RLS, functions, migrations	Cross-tenant denial
End-to-end	Doctor-hospital-admin journeys	Publish -> apply -> select -> complete
Security	SAST/DAST/mobile/upload/session abuse	Privilege escalation attempt
Performance	Search, selection race, outbox backlog	Pilot peak + safety margin
Recovery	Backup restore and incident runbook	Isolated restore drill

8. ENGINEERING

Device, Network and Accessibility Matrix

The Android-first pilot must work on realistic devices and unstable mobile networks common to duty users.

Dimension	Required coverage
Android	Supported minimum through current target SDK; at least low/mid/high memory classes
Screen	Small phone, common 6.x-inch device, large font and display scaling
Network	Wi-Fi, 4G, high latency, packet loss, offline interruption and retry
Lifecycle	Background/foreground, process death, notification deep link, token refresh
Accessibility	TalkBack labels, focus order, 4.5:1 body contrast, touch targets, text scaling
Battery/data	No continuous location; bounded background work; compressed uploads

8. ENGINEERING

Delivery Plan - Approximately 10 Weeks

The plan is a technical sequencing baseline, not a commercial quotation. Parallel work is possible only when acceptance ownership is clear.

Window	Engineering outcome	Exit evidence
Week 1	Architecture baseline, schemas, design system, environments, CI	ADRs + skeleton builds
Weeks 2-3	Auth, consent, roles, doctor/hospital profiles, verification upload	Integrated identity journey
Weeks 4-5	Duty marketplace, posting, applications, selection	End-to-end marketplace test
Weeks 6-7	Admin verification/moderation, notifications, completion/feedback	Operational pilot workflow
Week 8	Security/load/device/UAT remediation and Phase 1 staged release	Phase 1 gate signed
Week 9	Availability, alerts, history/wallet, reliability	Phase 2 trust tests
Week 10	Replacement, disputes, regression, staged Phase 2 release	Phase 2 gate signed

8. ENGINEERING

Play Store Release Strategy

Mobile/backend compatibility is maintained while updates roll through closed testing, controlled pilot and gradual production cohorts.

Release sequence

- Internal testing: staff and synthetic accounts.
- Closed testing: verified pilot doctors and hospitals.
- Production staged rollout: small cohort, observe, expand, pause or rollback through feature flags.
- Phase 2 modules ship disabled, then enable by cohort after migration and operational readiness.

Compatibility controls

- /v1 APIs remain backward compatible during rollout.
- app_versions controls minimum supported build and soft/forced update message.
- Remote flags separate code deployment from feature activation.
- Database migrations are expand-first; old clients never see a removed field during rollout.
- Kill switches disable matching, uploads or contested transitions independently.

8. ENGINEERING

Phase 1 Acceptance Matrix

Phase 1 is accepted only when the complete marketplace loop is demonstrably secure and operable.

Outcome	Acceptance condition
Identity	Doctor and hospital staff can authenticate, consent, select role and revoke session
Verification	Private evidence -> official-source review -> reasoned decision -> correct badge
Marketplace	Verified hospital publishes; eligible doctor searches and applies once
Selection	Hospital selects atomically; doctor confirms; no double assignment
Completion	Assignment completes with immutable terms/history and two-way feedback
Administration	Least-privilege queues, moderation, config and audited actions work
Security	No critical/high unresolved issue; RLS, upload and session negative tests pass
Operations	Monitoring, backup, support and rollback runbooks are assigned and rehearsed

8. ENGINEERING

Phase 2 Acceptance Matrix

Phase 2 is accepted when trust features are explainable, recoverable and compatible with Phase 1 history.

Outcome	Acceptance condition
Availability	Recurring rules and exceptions produce deterministic match eligibility
Alerts	Urgent notifications respect preference, eligibility, deduplication and server expiry
Wallet/history	Completed duties and acknowledgments reconcile to canonical assignment events
Reliability	Dimensions are policy-versioned, sample-aware, non-clinical and appealable
Replacement	Cancellation can reassign atomically without losing original history
Disputes	Evidence is private; decisions and one-level appeals are permissioned/audited
Rollout	Features can be enabled by cohort and disabled without corrupting Phase 1 workflow

8. ENGINEERING

Definition of Done

A story is done only when it is production-supportable, not merely visible in a demo build.

Code and contract

- Reviewed code; typed contract; migration and rollback consideration; no embedded secrets.
- Loading, empty, validation, conflict and recoverable-error UI states.
- Server authorization, RLS and audit implemented.

Evidence

- Unit/integration/negative tests pass.
- Security and accessibility checks relevant to the story pass.
- Analytics event and operational dashboard impact documented.
- Acceptance evidence linked to the work item.

Operations

- Runbook/support note updated.
- Feature flag and rollback behavior tested.
- User-facing text reviewed for medical, payment and verification claims.

8. ENGINEERING

Developer Handover Package

The final handover must allow a competent replacement team to build, deploy, operate and troubleshoot the system without relying on undocumented conversations.

Artifact	Required content
Source	Mobile, admin, functions/backend, migrations and tests with immutable release tag
Architecture	ADRs, diagrams, domain/state definitions and threat model
API	OpenAPI specification, sample requests/errors and environment base URLs
Database	Data dictionary, ER model, RLS matrix, migration/seed instructions
Operations	Deployment, rollback, backup/restore, incident and support runbooks
Security	Scan reports, residual-risk register, secret rotation and access review
Release	Signed build instructions, Play Console tracks, release notes and feature flags
Ownership	Accounts, environments, integrations and named operational owners

APPENDIX A

Canonical Enumerations

Enums are stored as controlled values and mapped through typed client models. Additions are backward compatible; removals require migration.

Domain	Canonical values
duty_status	draft, published, paused, filled, in_progress, completed, closed, cancelled
application_status	submitted, shortlisted, selected, rejected, withdrawn, expired
assignment_status	selected, confirmed, in_progress, completed, replaced, cancelled, disputed, closed
verification_status	draft, submitted, under_review, needs_information, approved, rejected, expired, suspended
replacement_status	requested, searching, candidate_offered, accepted, reassigned, failed, cancelled, closed
dispute_status	open, awaiting_response, under_review, decided, appealed, closed
notification_status	pending, processing, delivered, failed, dead_letter

APPENDIX B

Source Standards and Authoritative References

Developers must verify the latest official requirements before production release; these references define the intended control direction.

Area	Reference
Doctor verification	National Medical Commission Indian Medical Register / National Medical Register and relevant State Medical Council official sources
Mobile security	OWASP Mobile Application Security Verification Standard (MASVS)
API/admin security	OWASP Application Security Verification Standard (ASVS) and OWASP API Security guidance
Data protection	Applicable Indian data-protection law, rules and notices validated by qualified counsel before launch
Incident handling	CERT-In directions and applicable reporting obligations validated by security/legal owners
Platform	Official Flutter, Supabase, Firebase and Google Play documentation for supported versions

LEGAL BOUNDARY This technical blueprint is not legal or medical-regulatory advice. Product claims, notices, retention and incident duties require qualified review before production.

APPENDIX C

Final Architecture Position

The correct first build is a secure duty marketplace with a data model strong enough to become a trusted workforce network - without prematurely implementing recruitment, AI or commerce modules.

What must exist now

- Stable identity and organization membership model
- Explicit state machines and immutable event history
- Deny-by-default RLS and private evidence storage
- Verification source adapter and auditable manual workflow
- Transactional outbox and versioned API contracts
- Feature flags, migrations, observability and runbooks

What Phase 2 proves

- Availability improves matching
- Operational reliability can be explained fairly
- Cancellations can be recovered through replacement
- Disputes can be handled with evidence and appeal
- The platform can scale cohorts safely through Play Store updates

DEVELOPER MANDATE Build the platform as a trustworthy operational system, not a collection of screens.